



XELOR · TECHNICAL STRATEGY

Technology Stack & Production Roadmap

What the demo actually runs, what production still needs, the extension points already reserved, and a pragmatic target stack for a dependable manufacturing product.

Prepared from the running repository and live workflow audit

31 July 2026

1. Executive decision

XELOR has a strong product-engineering foundation for a demo: a TypeScript monorepo, a boundary-enforced modular monolith, PostgreSQL with forced tenant isolation, Keycloak identity, durable approval/audit patterns, event delivery, a real Next.js application, and a governed AI spine. The current build also includes a cross-industry Decision & Risk Commander, durable evidence links and a verified-outcome ledger. The right production move is to harden and operate this architecture—not rewrite it or split it into microservices.

Recommended direction: retain the modular monolith through product-market fit; deploy separate Web, API and Worker containers; move state to managed AWS services in Mumbai; add observability, recovery, security automation and CI/CD; close the manufacturing workflow gaps before adding architectural complexity.

Security and reliability reality: no honest architecture is unbreachable or incapable of failure. The production target is a resilient, recoverable, least-privilege system with defence in depth, small blast radii, tested restoration, continuous detection and measurable service objectives.

What is unusually good

- Tenant context is derived from verified identity and reinforced by PostgreSQL FORCE RLS.
- Ledger-critical writes stay transactional and use controlled write paths.
- Audit, approvals and AI actions are append-only and tamper-evident.
- Domain boundaries and provider ports leave credible exit paths.
- The demo is deterministic and rebuildable instead of relying on fragile fake screens.

What blocks production

- No production cloud deployment, autoscaling or managed recovery is implemented.
- Telemetry, alerting, incident response and SLOs are not yet operational.
- Several core manufacturing workflows remain incomplete.
- Backup claims need automated restore drills and evidence.
- Security assurance, load testing, accessibility and release governance need formal gates.

Status language used in this report

LIVE wired and exercised in the prototype **PARTIAL** real foundation but incomplete production behavior **RESERVED** a deliberate interface/schema extension point **RECOMMENDED** proposed after the demo.

4 workspace packages/apps	26 NestJS controller surfaces	228 migration CREATE TABLE declarations	7/7 Agent OS identities connected
------------------------------	----------------------------------	--	--------------------------------------

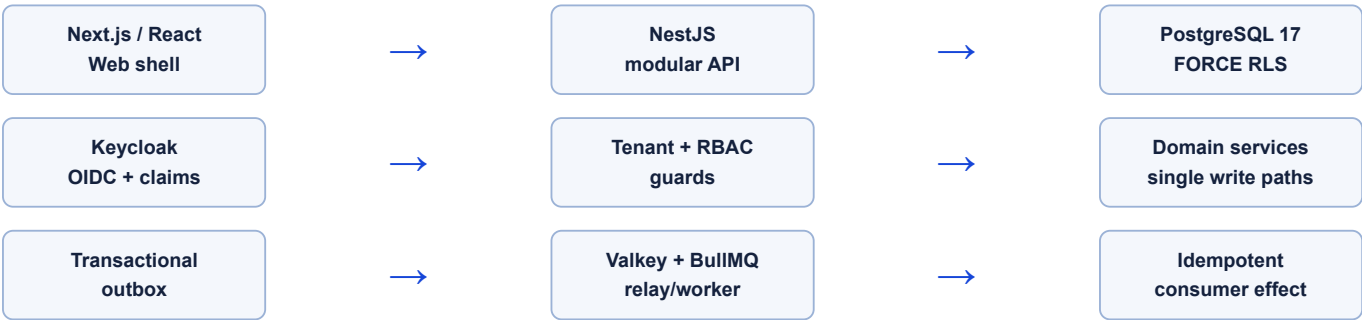
Counts are repository observations, not a claim that every table or endpoint is complete for commercial production.

2. Stack used to build and run the demo

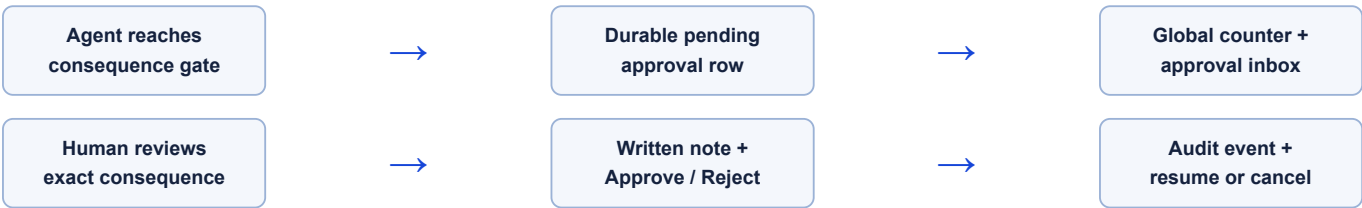
Layer	Technology in repository	Status	What it does today
Runtime & language	Node.js 22; TypeScript 5.7; ESM	LIVE	One language across browser, API, platform rules, tests and workers.
Monorepo	pnpm 9 workspaces	LIVE	Coordinates <code>apps/web</code> , <code>apps/api</code> , <code>packages/platform</code> and <code>packages/db</code> .
Web application	Next.js 15 App Router; React 19; Tailwind CSS 4; Radix UI; Lucide; Three.js	LIVE	Authenticated XELOR shell, horizontal module tabs, global Human Approvals entry with live pending count, dedicated approval inbox, department gateway, ONYX rail, Mission Control and an adaptive 3-D digital-twin sign-in scene.
API	NestJS 11; Express adapter; RxJS; SWC build	LIVE	Boundary-oriented modular monolith with 26 controller surfaces.
Validation	Zod 3	LIVE	Validates most request bodies and agent capability inputs; a few documented endpoints still bypass the pattern.
Database	PostgreSQL 17; pgvector; pg_trgm; btree_gist	LIVE	Transactional ERP system of record, vector-ready columns, fuzzy master matching and constraint-backed invariants.
Data access	Drizzle ORM 0.36; SQL migrations; node-postgres	LIVE	Typed schema access plus explicit migrations and operational checks.
Tenancy	AsyncLocalStorage context + <code>SET LOCAL</code> + PostgreSQL FORCE RLS	LIVE	Fail-closed shared-schema tenant isolation; portal adds customer-account scoping.
Identity	Keycloak 26; OIDC Authorization Code + PKCE; jose/JWKS; in-app RBAC	LIVE	Signed tenant claims, personas and permissions. The callback exchange is single-flight and retains tab-scoped PKCE state until success. The visibly labelled local demo theme provides one-action ENTER XELOR access on both initial and repeat authentication screens, mapping arbitrary or empty fields to an isolated seeded presenter identity; production retains strict IdP authentication.
Queue & cache	Valkey 8; BullMQ 5; ioredis	LIVE	Outbox relay and idempotent asynchronous consumption; local cache/broker foundation.
Audit & workflow	Hash chains; append-only tables; W1 approval engine; Agent OS human gates	LIVE	Tenant-scoped pending inbox, permission-checked Approve/Reject, mandatory decision note, identity/time attribution, durable pause/resume and tamper evidence.
AI	Thin provider router; deterministic stub; optional Ollama; custom eval harness; Agent OS; Decision Commander	PARTIAL	Cross-module analysis, missions and approvals are live; language reasoning remains deterministic and no hosted provider is active.
Decision data	PostgreSQL evidence-link graph and outcome metrics with RLS, audit and explicit verification state	LIVE	Estimated exposure and verified value are stored and reported separately; verification requires observed data, method and named reviewer.
Testing	Node test runner; Playwright 1.55; ESLint 9; TypeScript checks	LIVE	Unit/pure-rule tests, boundary checks and authenticated browser workflows, including all 13 guided-demo journeys and 110 presenter steps with a no-write assertion.
Local infrastructure	Docker Compose; Keycloak; PostgreSQL; Valkey; Gotenberg	LIVE	Reproducible local services. This is not yet a production deployment topology.

Branding note: internal package, database and Keycloak realm identifiers still use the historical deployment slug in places. They are technical contracts, not rendered product copy. Renaming them is possible but should be a separately rehearsed infrastructure migration—not a search-and-replace during demo hardening.

3. Architecture that exists now



Human-in-the-loop architecture now visible in the product



- **Discoverable everywhere:** authorised users see a labelled Approvals control in the global top bar; pending work carries a count and attention state.
- **One real source:** the counter and inbox read the tenant-scoped Agent OS approval table, not a second presentation-only queue.
- **Deliberate decision:** approval requires a written note; the user identity, note, decision and time are retained in the operational and audit records.
- **Narrow authority:** approval releases only the exact proposed action. It does not grant wider agent access or approve future missions.
- **Fail-safe behavior:** rejection cancels the mission; approval resumes from the persisted graph state and side-effect ancestry is verified again.

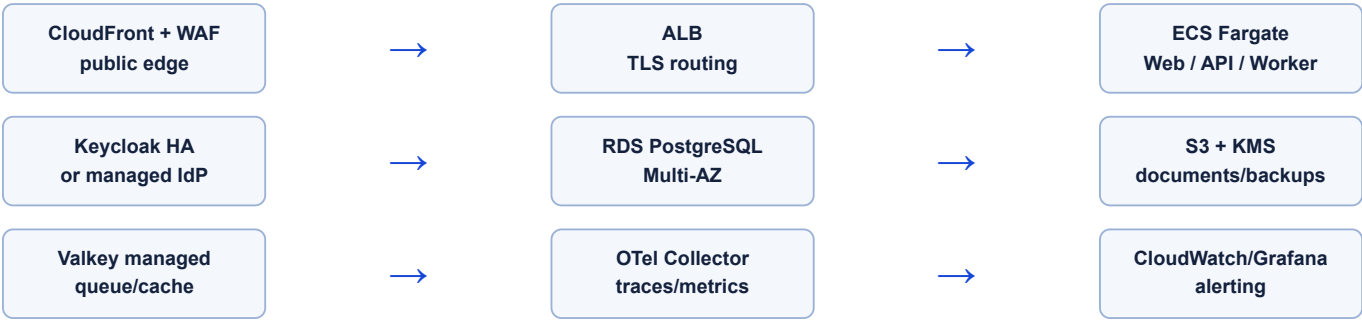
New domain operating surfaces

Module	Agent owner	Implemented user surface	Current data truth
Working Capital	RASP Finance & Working Capital	Overview, money in/out, stock holding cash, margins, 13-week forecast, scenarios and finance readiness pack.	Agent capabilities read tenant-scoped Accounts data; module KPIs and action stories remain curated demo scenarios until forecast/collection persistence is added.
QMS & Audit	KILN Operations & Quality	Overview, live inspections, NCR, containment, root cause, CAPA, controlled documents, audits, training and evidence packs.	Inspections and the Northstar NCR/CAPA thread are persisted system-of-record reads; document/audit breadth remains explicitly illustrative.
Human Approvals	HEXA governance + named human	Global counter, dedicated inbox, consequence preview, mandatory note, Approve/Reject and Mission Control handoff.	Live Agent OS pending records and decision API; permission and tenant checks are enforced server-side.

Why the modular monolith is the correct near-term shape

- Manufacturing transactions cross inventory, quality, production, purchasing and accounts; keeping correctness in one transactional boundary is currently more valuable than independent service scaling.
- Module boundaries are already explicit. Cross-module access uses ports/services or outbox events, giving a future extraction path without paying distributed-systems cost now.
- API, web and worker processes can scale independently even while sharing one codebase and database.
- The current team can debug one deployment and one data model while the product and workflows are still moving quickly.

Production topology recommended after the demo



Do not introduce Kubernetes yet. ECS/Fargate fits three container workloads without a control-plane burden. Reconsider EKS only when team size, workload diversity, GPU scheduling, multi-region policy or platform engineering requirements justify it.

4. Stack needed immediately after the demo

Capability	Recommended stack	Why it is required	Exit criterion
Container delivery	Docker multi-stage images, Amazon ECR, ECS/Fargate, ALB, CloudFront, WAF	Immutable releases, health checks, horizontal scaling and safe external exposure.	Rolling or blue/green release with tested rollback and no manual server mutation.
Managed database	RDS PostgreSQL Multi-AZ, encrypted storage, PITR, parameter groups; RDS Proxy or PgBouncer only after measurement	Failover, backups and operational ownership suitable for a system of record.	Documented RPO/RTO met in a restore/failover exercise.
Managed broker	Amazon ElastiCache for Valkey or an equivalent managed Valkey service	Removes single-host queue/cache risk while preserving BullMQ semantics.	Queue replay, poison message and broker-failover tests pass.
Object/document storage	S3, KMS, presigned upload/download, antivirus scan queue, lifecycle policies	Receipts, certificates, drawings, exports and evidence must not live on container disks.	Every document has tenant ownership, checksum, retention and access audit.
Secrets	AWS Secrets Manager + KMS; short-lived workload identity; no static cloud keys	Database, OIDC and connector credentials need rotation and access evidence.	Production contains no secret in source, image, task definition or developer shell history.
Infrastructure as code	OpenTofu modules; remote encrypted state; environment/account separation	Reproducible Mumbai primary and Hyderabad recovery environments.	A clean account can be built from reviewed code.
CI/CD	GitHub Actions with OIDC federation; build, SBOM, signing, tests, migration check, deploy and rollback	Turns the existing local quality gates into release policy.	No production deploy bypasses the pipeline; provenance is retained.
Observability	OpenTelemetry Node instrumentation and Collector; CloudWatch/Grafana; Sentry or equivalent error tracking	Correlates browser, API, database, queue and AI behavior without reading raw production data.	SLO dashboards and actionable alerts cover the critical workflows.
Security edge	WAF, Shield baseline, private subnets, VPC endpoints, GuardDuty, Security Hub, CloudTrail	Reduces attack surface and supplies security evidence.	Threat model, penetration test and critical finding remediation completed.
Notifications	SES/SNS initially; provider abstraction for WhatsApp/SMS vendors	Approvals, escalations, customer/service events and operational alerts need reliable delivery.	Templated, tenant-aware, consent-aware delivery with bounce/retry evidence.

5. Space deliberately left for future stacks

Existing extension point	Current implementation	What can plug in later	Trigger to adopt
<code>AIProvider</code> / thin router	Deterministic stub or Ollama by configuration	OpenAI Responses API adapter, Amazon Bedrock Converse, Gemini or another approved provider	A feature passes its eval/grounding/privacy gate and has an agreed data-processing posture.
<code>WorkflowExecutor</code>	In-house W1 approvals	Temporal for long-running, cross-system workflows	Workflows last days, require many compensations/signals, or W1 operations become costly.
Outbox/event envelope	PostgreSQL → BullMQ/Valkey	Kafka/MSK, EventBridge or CDC for higher fan-out and independent consumers	Sustained throughput/fan-out or external analytics proves the current relay insufficient.
Domain ports	In-process Nest services	Extracted services behind HTTP/gRPC/events	A module needs independent ownership, scaling, release cadence or isolation—and the cost is measured.
pgvector columns/indexes	Extension enabled; knowledge-base vector field provisioned	Authorized RAG over manuals, drawings, SOPs and cases; external vector DB only if scale requires	Document ingestion, permissions and retrieval evals are ready.
Gotenberg	Local HTML-to-PDF container	Production document service with templates, signatures and archival	Quotes, invoices, payslips, certificates and compliance exports require governed rendering.
Keycloak OIDC	Local realm, personas and custom theme	SAML/LDAP federation, enterprise organizations, MFA/WebAuthn, SCIM provisioning	First enterprise customer identity requirements.
Integration/webhook module	Signed webhooks, retry/DLQ, statutory demo connectors	GSP, bank, logistics, payment and supplier adapters through connector workers	Contract, sandbox certification and reconciliation design are complete.
Analytics read path	Operational queries on PostgreSQL	Read replica, CDC to S3/Iceberg and a warehouse/query engine	BI queries materially affect ERP latency or cross-tenant analytics is required.

Architectural advantage: the repository already contains more credible exit paths than the demo needs. The discipline is to adopt each new stack only when its operational trigger occurs.

6. Product gaps that matter more than new infrastructure

The repository's capability-gap register was produced by trying to execute the Northstar story. These are product workflow issues, not presentation polish.

Priority	Gap	Production impact	Recommended treatment
Resolved	Batch/lot consumption	FIFO allocation now consumes batch-tracked receipts through the single stock write path and records explicit splits.	Keep the allocation and insufficiency regression tests in the release gate; extend genealogy reporting for production.
Resolved	Idempotency/validation consistency	Database conflicts map to safe 409 responses; the identified maintenance and expenditure paths validate and deduplicate requests.	Retain conformance probes in the 87-check investor acceptance matrix.
P1	Quotation and opportunity	The commercial process starts at a committed sales order.	Add lead/opportunity, quote revisions, validity, approvals and quote-to-order conversion.
Resolved	Production operations	Northstar production reports four predecessor-gated operations with operator, time, quantities and evidence.	Deepen labour/machine booking and WIP analytics for production deployments.
Resolved	Persisted NCR/CAPA	The rejected inspection has a persisted NCR, containment, root cause and CAPA whose effectiveness review remains human-owned.	Extend toward full 8D, attachment lifecycle and customer-specific approval routes.
P1	Supplier invoice/AP/payment	Direct-material purchase cycle stops at goods receipt.	Supplier invoice, three-way match, exceptions, AP ageing and controlled payment run.
P1	Engineering change control	BOM version exists but change intent, impact and effectivity are not governed.	ECR/ECO, where-used impact, stock disposition, approvals and effective-from revisions.
Resolved	Employee Spend UI	Claims and budget decisions are operable in a registered, permission-checked web module.	Expand travel/advance/indirect-spend screens as pilot scope requires.
P2	Cost-centre master	Employee and budget vocabularies do not align.	Create one governed organizational/cost-centre master referenced by both modules.

Keep the boundary explicit. Quotation/opportunity, engineering change control and supplier AP remain production-roadmap gaps; do not claim end-to-end manufacturing ERP completeness yet.

7. Phased production roadmap

Phase 0 — Demo confidence (now to 4 weeks)

- Keep the authenticated route crawl, real Keycloak login, Decision Commander and end-to-end approval-inbox tests in the release suite.
- Measure pending-approval age, decision turnaround, recovery outcome and rejection reasons; add escalation without bypassing authority.
- Extend the evidence graph through governed connectors while retaining source ownership and tenant fencing.
- Produce signed container builds and keep the isolated top-level demo reset as a release check.
- Define data classification, tenant onboarding/offboarding and a minimum threat model.

Phase 1 — Pilot-ready foundation (1 to 3 months)

- Deploy Web/API/Worker on ECS/Fargate in Mumbai with RDS Multi-AZ, managed Valkey, S3/KMS and Secrets Manager.
- Implement OpenTofu, CI/CD, SBOM/signing, migrations-as-a-gate and environment promotion.
- Add OpenTelemetry, error tracking, database/queue dashboards and on-call runbooks.
- Enable MFA, session policy, rate limits, WAF, audit exports, restore drills and customer-isolated test environments.
- Close quotation/opportunity so a pilot follows the commercial process before commitment.

Phase 2 — Controlled production (3 to 9 months)

- Deepen operation execution and NCR/CAPA breadth; add AP/three-way match and engineering change control.
- Add document/object lifecycle, connector certification, reconciliation queues and customer notification channels.
- Run performance, chaos/failover, accessibility, mobile-responsiveness and penetration-test programs.
- Introduce a hosted AI provider only for features that pass offline and shadow-mode evaluation.

Phase 3 — Scale and ecosystem (9 to 18 months)

- Add read replicas/analytics CDC only after workload evidence; introduce Temporal only for workflows that exceed W1.
- Enterprise federation, SCIM, dedicated-tenant deployment option and multi-region recovery rehearsal.
- Public partner APIs, connector SDK/contracts, metering/billing and customer-facing status/audit exports.

8. Production quality gates and operating targets

Area	Minimum gate before commercial production	Example target
Availability	Multi-AZ services, health-based replacement, tested rollback and failover	Start with 99.9% monthly for core API; increase only with evidence and support capacity.
Recovery	Encrypted PITR plus quarterly full restore and audit-chain verification	RPO ≤ 15 minutes; RTO ≤ 4 hours for initial pilots, contractually reviewed.
Performance	Representative tenant/data load tests and slow-query budget	p95 read API < 500 ms and mutation < 1 s excluding deliberate approvals/external calls.
Security	Threat model, SAST/SCA/secret scanning, SBOM, signed artifacts, penetration test	Zero unresolved critical/high exploitable findings at release.
Tenancy	Automated two-tenant leak probes for every schema/policy change	Zero cross-tenant visibility at API and SQL layers.
Data correctness	Property/invariant tests for inventory, GL, tax, payroll, approvals and numbering	No ledger mutation outside the canonical transactional service.
Accessibility	Keyboard, focus, screen-reader and contrast tests for critical workflows	WCAG 2.2 AA target for the customer-facing and core operational paths.
AI	Feature-specific eval, grounding, privacy review, shadow mode, kill switch and rollback	No model-written financial/inventory transaction; 100% consequential actions attributable to approval.

Operational runbooks required

Platform

- Database saturation/failover
- Queue backlog and poison message
- Keycloak outage/signing-key rotation
- Bad migration and application rollback
- Object store or KMS denial

Business integrity

- Broken stock/GL invariant
- Duplicate statutory submission
- Audit-chain verification failure
- Tenant isolation incident
- AI kill switch and provider incident

9. What not to add yet

Tempting stack	Why not now	Adopt when...
Kubernetes/EKS	Three primary workloads do not justify cluster platform operations.	There are many independently owned workloads, GPU scheduling or multi-cluster policy needs.
Microservices	Would distribute transactions and debugging before domain/product boundaries have stabilized.	A measured module-level scaling, release or isolation constraint exists.
Kafka/MSK	BullMQ/outbox is adequate for current volume and simpler to operate.	Replayable high-volume streams, many consumer teams or analytics fan-out require it.
Separate vector database	pgvector is co-located with permissions and sufficient for the first authorized RAG workloads.	Index size/latency/recall measurements exceed PostgreSQL's practical envelope.
General-purpose agent framework	XELOR already has a domain-bounded graph runtime with stronger approval ancestry than generic wrappers provide.	A framework supplies a concrete missing capability without weakening controls or duplicating state.
Data lake/warehouse on day one	Creates governance and duplicated-data burden before operational query load is known.	BI workloads harm ERP performance or historical/cross-tenant analytics has a funded owner.

A “perfect running product” is not a stack list. It is an architecture that stays understandable, restores correctly, preserves business invariants, exposes its failures, and can be changed safely. The recommendation above optimizes for those properties.

10. Evidence and reference basis

Repository evidence inspected

- `package.json` and all workspace package manifests
- `infra/docker-compose.yml`, Keycloak realm/theme and PostgreSQL initialization
- `packages/db` schemas, migrations, RLS/permission checks and demo reset
- `apps/api` domain modules, common guards, worker/outbox, workflow, AI and Agent OS
- `apps/web` module manifests, shell, Copilot rail and Playwright workflows
- `docs/02-investor-demo/02-capability-gaps.md`
- Authenticated browser audit of the running XELOR application on 31 July 2026

Official external references used for future recommendations

- Amazon ECS architecture and Fargate: docs.aws.amazon.com/AmazonECS/latest/developerguide/application_architecture.html
- Amazon RDS for PostgreSQL and Multi-AZ: docs.aws.amazon.com/AmazonRDS/latest/UserGuide/CHAP_PostgreSQL.html
- OpenTelemetry JavaScript/Node.js: opentelemetry.io/docs/languages/js/getting-started/nodejs/
- Temporal durable execution (future trigger, not immediate recommendation): docs.temporal.io/temporal
- Three.js post-processing and WebGPU renderer guidance: threejs.org/manual/en/post-processing.html and threejs.org/manual/en/webgpurenderer
- React Three Fiber performance scaling: r3f.docs.pmnd.rs/advanced/scaling-performance
- Browser glass and motion-accessibility primitives: [MDN backdrop-filter](https://developer.mozilla.org/en-US/docs/Web/API/BackdropFilter) and [MDN reduced-motion guidance](https://developer.mozilla.org/en-US/docs/Web/API/ReducedMotion)

Final recommendation

Keep the core stack. Invest next in managed operations, observability, recovery, security and the missing manufacturing workflows. Use the ports already present to introduce hosted AI, durable workflow or higher-scale event infrastructure only when a tested product need calls for them.

This report describes the repository and local deployment inspected on 31 July 2026. "Live" means implemented and exercised in the prototype; it does not imply production certification, contractual availability or regulatory approval.